

SecureOrg Inc.

PCI DSS Compliance Framework

Data Handling and Encryption Policy

Document Reference:	DHEP-006
Version:	2.2
Effective Date:	April 14, 2026
Document Owner:	Chief Information Security Officer
Classification:	CONFIDENTIAL
Review Cycle:	Annual
Framework:	PCI DSS v4.0

This document contains confidential and proprietary information. Unauthorized disclosure is prohibited.

1. Purpose and Scope

1.1 Purpose

This Data Handling and Encryption Policy establishes requirements for the protection of cardholder data (CHD), sensitive authentication data (SAD), and other sensitive information throughout its lifecycle. The Policy implements PCI DSS v4.0 Requirements 3 (Protect Stored Account Data) and 4 (Protect Cardholder Data with Strong Cryptography During Transmission Over Open, Public Networks), ensuring that CHD is protected from unauthorized disclosure whether at rest, in transit, or in use.

1.2 Scope

This Policy applies to all individuals and systems that store, process, or transmit cardholder data, sensitive authentication data, or other sensitive organizational data as defined in the information classification framework.

2. Data Classification and Handling Requirements

2.1 Cardholder Data Inventory

The organization shall maintain a current, comprehensive inventory of all locations where CHD is stored, processed, or transmitted. This data flow inventory shall include:

- All systems, applications, and databases holding CHD
- All data flows showing CHD movement between systems
- Storage format and encryption status for each location
- Retention purpose and period for each CHD data set
- Business owner responsible for each CHD location

The CHD inventory shall be reviewed and verified quarterly, and updated within 30 days of any system change that affects CHD flows.

2.2 Prohibited Data Storage

The following data must never be stored after transaction authorization, regardless of encryption status (PCI DSS Requirement 3.2):

Full track data (magnetic stripe / chip equivalent)	NEVER store post-authorization	Includes track 1, track 2, and chip equivalent data
Card verification values (CVV2, CVC2, CID)	NEVER store post-authorization	Even if encrypted or hashed
PIN and PIN Blocks	NEVER store post-authorization	Regardless of encryption method

2.3 Permitted and Required CHD Handling

Primary Account Number (PAN)	Yes, if necessary	Encrypt at rest; mask when displayed (first 6 / last 4 only)
Cardholder Name	Yes, if necessary	Protect; store only with business justification
Service Code	Yes, only with PAN	Protect as part of CHD
Expiration Date	Yes, only with PAN	Protect as part of CHD

3. Data Retention and Disposal

3.1 Retention Policy

CHD shall be retained only for the minimum period necessary to satisfy legal, regulatory, or documented business requirements. The organization's data retention schedule defines specific retention periods for each CHD data category. Key principles:

- The default retention period for CHD is 12 months from the date of the transaction unless a longer period is required by law
- CHD retained beyond the minimum required period must have documented business justification approved by the Data Owner
- Retention periods shall be reviewed annually and adjusted as business or regulatory needs change

3.2 Secure Data Disposal

Upon expiration of the retention period, CHD must be securely disposed of using one of the following approved methods:

- Cryptographic erasure: Destruction of encryption keys used to protect the data, rendering it unrecoverable
- Secure overwrite: Multiple-pass overwrite using NIST SP 800-88 compliant methods (Purge or Destroy as appropriate)
- Physical destruction: Shredding, degaussing, or physical destruction of storage media (for removable media or decommissioned hardware)

Disposal must be documented with a record including: data description, disposal method, date, and the name of the individual who performed or authorized the disposal.

3.3 Quarterly Data Discovery

A quarterly automated scan shall be conducted across all CDE and connected systems to discover any stored SAD or CHD that exceeds the approved retention period. Scans shall use approved data discovery tools configured to detect:

- PANs in databases, files, and unstructured storage
- Track data patterns in storage
- CVV patterns indicating potentially stored SAD

4. Encryption Requirements

4.1 Approved Cryptographic Algorithms

Symmetric encryption (data at rest)	AES-256, AES-128 (minimum)	DES, 3DES, RC4, RC2, Blowfish
Asymmetric encryption (key exchange)	RSA-2048+, ECDH P-256+	RSA < 1024 bits
Hashing (integrity / non-PAN)	SHA-256, SHA-384, SHA-512	MD5, SHA-1 (for security purposes)
Transport Layer Security	TLS 1.2, TLS 1.3	SSL (all versions), TLS 1.0, TLS 1.1
Digital signatures	RSA-SHA256+, ECDSA P-256+	MD5withRSA, SHA1withRSA

4.2 Encryption of CHD at Rest

All stored CHD must be protected using strong encryption:

- Full PAN must be encrypted at rest using AES-256
- Database column-level or tablespace encryption is acceptable for database storage
- Full disk encryption alone is not sufficient for CHD; application-layer or database encryption is required in addition
- Backup copies of CHD must be encrypted using the same or stronger standards
- Encrypted data must be stored separately from the encryption keys

4.3 Encryption in Transit

All CHD transmitted over open, public networks (including the internet) must be encrypted using approved protocols:

- TLS 1.2 minimum; TLS 1.3 preferred for all CHD transmissions
- TLS certificates must be from approved Certificate Authorities with a minimum 2048-bit RSA key
- Certificate expiry monitoring must be in place with alerts at 60 and 30 days before expiry
- HSTS (HTTP Strict Transport Security) must be implemented on all web-based CHD interfaces
- Mixed content (HTTP and HTTPS) is prohibited on any page that handles CHD

5. Key Management

5.1 Key Management Principles

Cryptographic key management is fundamental to the effectiveness of encryption controls. Keys

must be:

- Generated using cryptographically random number generators (NIST-approved)
- Of sufficient length as per the algorithm requirements above
- Stored separately from the data they protect
- Protected by another layer of encryption (key encryption keys)
- Accessible only to those with a documented need for key access

5.2 Key Lifecycle

Generation	Use FIPS 140-2 Level 2 validated HSM or CSPRNG; document algorithm, key length, and purpose
Distribution	Encrypt under key encryption key; split knowledge / dual control for master keys
Storage	Store in HSM or approved key management system; never in plaintext in code or config files
Use	Keys used only for authorized purpose; access logged
Rotation	Data encryption keys rotated annually or upon personnel change; key encryption keys rotated every 2 years
Revocation	Immediate revocation upon compromise; document in key register
Destruction	Cryptographic erasure; document with date and method

5.3 Split Knowledge and Dual Control

For master keys and key encryption keys protecting CHD, split knowledge and dual control must be implemented such that no single individual has access to the complete key. Procedures must ensure:

- Master key components are held by at least two individuals (custodians)
- Key custodians understand their responsibilities and have completed key management training
- No single custodian can reconstruct the complete key alone

6. Tokenization and Masking

6.1 Tokenization

Tokenization is an approved method for protecting CHD by replacing the PAN with a non-

sensitive surrogate value (token). Tokenization implementations must:

- Use a format-preserving tokenization solution approved by the Information Security team
- Ensure the token vault (mapping table) is secured with the same controls as CHD
- Ensure tokens cannot be reversed to obtain the original PAN without access to the token vault
- Comply with PCI SSC guidance on tokenization

6.2 PAN Masking

When displaying PAN in user interfaces, reports, or logs:

- A maximum of the first 6 and last 4 digits shall be visible; all other digits must be masked (e.g., 4111 11** **** 1111)
- Full unmasked PAN may only be displayed to specifically authorized personnel with a documented business need
- All access to full unmasked PAN must be logged
- Masking must be implemented at the application layer, not relying solely on database or network controls

7. Revision History

1.0	Jan 15, 2024	Initial release	CISO Office
2.0	Apr 10, 2025	Major revision: algorithm table; key lifecycle; tokenization section added	Security Team
2.2	Apr 14, 2026	Annual review; TLS requirements; masking updates; quarterly discovery	CISO Office